CONFIDENTIAL

INCIDENT RESPONSE REPORT

Cloudora Microsoft 365 Account Takeover Investigation

Managed Detection & Response — Security Operations Center

REPORT ID	CLD-IR-0001
RELATED TICKET	CLD-0001
CLIENT	Cloudora
SEVERITY	P1(Critical)
STATUS	Closed
ANALYST	P.S.V.S.PRANAV, Tier-1 SOC Analyst
DATE OF REPORT	2026-10-30 (UTC)

Table of Contents

1. Report Information 3

2. Executive Summary 3

3. Incident Overview 4

4. Incident Timeline 4

5. Investigation Methodology 5

6. Findings 6

    6.1 Finding 1 - Daniel Reeve Account Compromise 6

    6.2 Finding 2 - Password Spraying Campaign 6

    6.3 Finding 3 - Persistence Established 7

    6.4 Finding 4 - Business Email Compromise Preparation 7

7. Indicators of Compromise (IOC) 8

8. MITRE ATT&CK Mapping 8

9. Scope of Incident 9

10. Business Impact 9

11. Containment Actions 10

12. Eradication Actions 10

13. Recovery Recommendations 10

14. Long-Term Security Improvements 11

15. Lessons Learned 11

16. Conclusion 11

17. Appendix 12

17.1 Important KQL Queries 12

17.2 IOC Summary 12

17.3 Investigation Notes 12

1. Report Information

Report ID	CLD-IR-0001
Related Ticket	CLD-0001
Report Title	Cloudora Microsoft 365 Account Takeover Investigation
Analyst	P.S.V.S.PRANAV, Tier-1 SOC Analyst
Date of Report (UTC)	2026-10-30
Incident Severity	P1 — CRITICAL
Status	CLOSED
Classification	Confidential - Internal and Client Distribution Only

2. Executive Summary

An investigation into a security breach found evidence of a successful takeover of accounts in Cloudora's Microsoft 365 platform after unusual authentication processes were noted. It was learned that the hacker organized a password spraying operation over several days to acquire login data and activated access to the accounts of two employees.

> **KEY RISK STATEMENT**
>
> Two confirmed compromised accounts, an unauthorized MFA persistence mechanism, and a mailbox rule designed to hide finance communications collectively indicate active preparation for financial fraud. Immediate containment was required to prevent fraudulent wire transfer or invoice manipulation activity.

Once access was obtained, the hacker demonstrated persistence by registering an unauthorized MFA device and setting up a fraudulent inbox rule to hide email correspondence relating to any finances, indicating a preparation process for a Business Email Compromise scheme.

Actions to respond immediately include eliminating unauthorized authentication methods, getting rid of harmful mailbox rules, restoring user account credentials, canceling current sessions, and checking all targeted users for more signs of hacking. The presence of multiple involved accounts, persistence mechanisms, and the possible effect on confidential financial and business information have led to the conclusion that the event is Priority 1 (Critical) event.

3. Incident Overview

On August 8, 2026, Cloudora's Security Information and Event Management (SIEM) system began to report multiple cases of failed login attempts on several Microsoft 365 accounts belonging to employees, most probably indicating the execution of a password spraying cyber-attack. In the next couple of days, the attacker tried low-and-wide approaches, targeting over 20 accounts to avoid triggering the limits on the number of failed login attempts.
On August 10, 2026, the mission brought its first results, as the attacker collected the login credentials from two accounts: daniel.reeve@cloudora.io and priya.nair@cloudora.io. After gaining entry into Daniel Reeve's account, the attacker added a foreign authentication device to ensure continuous access to the account, entered the Azure Portal and SharePoint Online, and devised an email filtering rule that hid the relevant messages regarding finances — predetermining the conditions for the Business Email Compromise fraud in the future.

Attack Vector	Password Spraying against Microsoft 365 authentication endpoints

Initial Access Technique	Valid Accounts (T1078)
Attacker Infrastructure	Three Nigerian-attributed IP addresses (102.89.x.x range)
Accounts Confirmed Compromised	2 (Daniel Reeve, Priya Nair)
Accounts Targeted	20+
Persistence Established	Yes — unauthorized MFA device registration
Data at Risk	Finance correspondence, SharePoint Online content

4. Incident Timeline

The table below reconstructs the attack lifecycle based on correlated Microsoft 365 sign-in and audit log telemetry (*CloudoraSignIn_CL* and *CloudoraAudit_CL*).

Time (UTC)	Source	Event	Evidence / Notes
2026-08-08	CloudoraSignIn_CL	Password spraying campaign initiated	Multiple failed authentication attempts observed from attacker infrastructure (102.89.x.x)
2026-08-09	CloudoraSignIn_CL	Password spraying campaign continued	Additional failed authentication attempts targeting multiple employee accounts
2026-08-10 03:12:05	CloudoraSignIn_CL	Successful authentication to Daniel Reeve's account	First successful login following repeated failed authentication attempts
2026-08-10 03:14:30	CloudoraSignIn_CL	Outlook Web accessed	Successful Outlook Web authentication from attacker infrastructure
2026-08-10 03:18:44	CloudoraAudit_CL	Unauthorized authenticator device registered	New MFA device ("Pixel 6") registered on Daniel Reeve's account
2026-08-10 03:26:02	CloudoraSignIn_CL	Azure Portal accessed	Successful Azure Portal authentication using Daniel Reeve's account
2026-08-10 03:31:09	CloudoraAudit_CL	Malicious inbox rule created	"RSS Subscriptions" rule created to hide finance-related emails
2026-08-10 03:47:18	CloudoraSignIn_CL	Successful authentication to Priya Nair's account	Second confirmed compromised account
2026-08-10 03:52:40	CloudoraSignIn_CL	SharePoint Online accessed	Post-compromise activity from attacker infrastructure

Table 1. Correlated incident timeline reconstructed from sign-in and audit log telemetry.

> **ANALYST OBSERVATION**
>
> The 36-hour gap between initial password spraying activity and successful compromise, followed by persistence establishment within six minutes of first access, indicates a semi-automated attack toolkit rather than manual operator activity during the initial access phase.

5. Investigation Methodology

Nimbus Shield adopted the Tier-1 response approach during the investigation as stipulated by NIST SP 800-61 incident management phases, specifically in the detection and analysis of incidents. Consequently, the following were achieved:

1.Log Source Identification: Authentication logs for Microsoft 365 (CloudoraSignIn_CL) and the unified audit logs (CloudoraAudit_CL) were verified for the availability of information.

2.Authentication Log Review: Sign-in logs were checked for potential failure (ResultType = 50126) and success (ResultType = 0) events to identify attempts to verify credentials by malicious activity.

3.Attacker Infrastructure Correlation: The source IP addresses were compared and matched for the flagged events leading to identification of the shared attacker infrastructure.

4.Audit Log Review: The respective unified audit logs for Microsoft 365 were reviewed for any activities performed post-authentication to search for malicious actions such as multifactor registration and rule creation in order to establish persistence in business email compromise.

5.Scope Determination: Information was collected on logins across the accounts to classify each account as being either confirmed breached, targeted or false positives.

6.MITRE ATT&CK Mapping: Findings were mapped too MITRE ATT&CK tactics as means of assisting detection engineering and in building intelligence reports.Note: This investigation was conducted within a training/simulated SOC environment. No live containment or eradication actions were performed against production systems; recommended actions are documented for reference and process validation purposes.

6. Findings

Four findings were substantiated through direct correlation of authentication and audit log evidence. Each finding is documented below with supporting evidence and business impact rationale.

Finding 1 — Daniel Reeve Account Compromise

FINDING

Daniel Reeve's Microsoft 365 account was successfully compromised following repeated failed authentication attempts originating from a Nigerian-attributed IP address.

EVIDENCE

Analysis of *CloudoraSignIn_CL* showed multiple failed authentication attempts (ResultType = 50126) followed by a successful Microsoft 365 authentication (ResultType = 0) from IP address 102.89.44.17. Subsequent successful access to Outlook Web and the Azure Portal was also observed from the same IP address.

WHY IT MATTERS

This confirms unauthorized access to a high-value executive account and marks the beginning of the confirmed account takeover.

Finding 2 — Password Spraying Campaign

FINDING

The attacker gained initial access through a password spraying campaign targeting multiple Cloudora employee accounts.

EVIDENCE

Authentication logs showed repeated failed login attempts from three Nigerian IP addresses (102.89.44.17, 102.89.44.23, and 102.89.45.101) over three consecutive days. More than twenty Cloudora user accounts were targeted, with only a few password attempts made against each account to avoid triggering lockout thresholds.

WHY IT MATTERS

This activity is consistent with MITRE ATT&CK T1110.003 – Password Spraying, a technique commonly used to avoid account lockout policies while identifying weak passwords across a large user population.

Finding 3 — Persistence Established

FINDING

The attacker established persistence by registering an unauthorized authenticator application on Daniel Reeve's account.

EVIDENCE

CloudoraAudit_CL recorded a "User registered security info" event, in which an authenticator device identified as "Pixel 6" was added to Daniel Reeve's account shortly after the successful compromise.

WHY IT MATTERS

Unauthorized MFA registration allows the attacker to retain account access even after a password reset, if the additional authentication method is not explicitly removed during remediation.

Finding 4 — Business Email Compromise Preparation

FINDING

The attacker created a malicious inbox rule to hide finance-related emails.

EVIDENCE

Audit logs recorded creation of the "RSS Subscriptions" inbox rule. The rule automatically moved emails received from finance@cloudora.io, or containing the keyword "invoice," into the RSS Feeds folder and marked them as read.

WHY IT MATTERS

This behavior is consistent with preparation for Business Email Compromise (BEC) by concealing financial communications from the legitimate account owner, a common precursor to fraudulent wire transfer or invoice redirection schemes.

7. Indicators of Compromise (IOC)

The following indicators were identified during the investigation and should be used for blocking, threat hunting, and detection rule creation across the environment.

Type	Value	First Seen (UTC)	Context
IP Address	102.89.44.17	2026-08-10 03:09	Password spraying and Daniel Reeve compromise
IP Address	102.89.44.23	2026-08-08 03:16	Password spraying campaign
IP Address	102.89.45.101	2026-08-10 03:44	Password spraying and Priya Nair compromise
Device Name	Pixel 6	2026-08-10 03:18	Unauthorized MFA registration
Inbox Rule	RSS Subscriptions	2026-08-10 03:31	Malicious mailbox rule

Type	Value	First Seen (UTC)	Context
Email Address	finance@cloudora.io	2026-08-10 03:31	Targeted by inbox rule
Keyword	invoice	2026-08-10 03:31	Used by malicious inbox rule

Table 2. Indicators of compromise identified during investigation.

8. MITRE ATT&CK Mapping

Confirmed findings were mapped to the MITRE ATT&CK framework to support detection engineering, threat intelligence enrichment, and executive-level risk communication.

Tactic	Technique ID	Technique Name	Evidence
Credential Access	T1110.003	Password Spraying	Finding 2
Initial Access	T1078	Valid Accounts	Finding 1
Persistence	T1098.005	Additional Cloud Credentials	Finding 3
Defense Evasion	T1564.008	Hide Artifacts: Email Hiding Rules	Finding 4

Table 3. MITRE ATT&CK tactic and technique mapping for confirmed findings.

9. Scope of Incident

9.1 Confirmed Compromised Accounts

Account	Evidence
daniel.reeve@cloudora.io	Both accounts showed successful authentication (ResultType = 0) from attacker-controlled Nigerian IP addresses following repeated failed authentication attempts.
priya.nair@cloudora.io	

9.2 Accounts Targeted but Not Breached

The following seventeen accounts recorded only failed login attempts (ResultType = 50126), with no successful authentication observed:

Account	Account	Account
rhys.owen@cloudora.io	lena.voss@cloudora.io	ruth.dean@cloudora.io
cole.burke@cloudora.io	mira.shah@cloudora.io	alba.vega@cloudora.io
liam.doyle@cloudora.io	seth.lane@cloudora.io	joel.kerr@cloudora.io
ethan.wells@cloudora.io	ryan.boyd@cloudora.io	kian.patel@cloudora.io
sofia.marino@cloudora.io	aria.reid@cloudora.io	dina.said@cloudora.io
emma.hayes@cloudora.io	gwen.muir@cloudora.io	

Table 4. Accounts targeted by the password spraying campaign with no successful authentication recorded.

9.3 Accounts Investigated and Cleared (False Positives)

Account	Evidence
omar.farah@cloudora.io	Although this account experienced failed password-spraying attempts from attacker infrastructure, subsequent successful authentication originated from the user's normal location with no evidence of persistence or suspicious post-authentication activity.

10. Business Impact

The confirmed compromise of two Microsoft 365 accounts, combined with the establishment of covert persistence and preparation activity targeting finance-related correspondence, presents material risk to Cloudora's operations and financial integrity.

- **Financial Fraud Risk: The malicious inbox rule concealing finance@cloudora.io and invoice-related correspondence indicates active preparation for Business Email Compromise, which could result in fraudulent payment redirection if not remediated promptly.**
- **Data Exposure Risk: Confirmed attacker access to SharePoint Online under Priya Nair's account may have exposed internal documents, depending on the user's access permissions and document library configuration.**
- **Persistence Risk: The unauthorized MFA device registration on Daniel Reeve's account allowed continued access independent of the original compromised password, extending the attacker's window of opportunity.**
- **Reputational Risk: Should the BEC preparation have progressed to execution, Cloudora and its business partners could have faced financial loss and reputational harm from a successful fraud attempt**.

> **IMPACT SUMMARY**
>
> No confirmed data exfiltration or fraudulent financial transaction has been identified at the time of this report. Impact is currently assessed as **contained but high-risk**, contingent on completion of the recommended remediation actions below.

11. Containment Actions

The following containment actions are recommended to be executed immediately by Cloudora's identity administration team to halt ongoing attacker access:

#	Action	Purpose
1	Disable or force sign-out of active sessions for daniel.reeve@cloudora.io and priya.nair@cloudora.io	Terminate any active attacker session tokens
2	Block source IP addresses 102.89.44.17, 102.89.44.23, and 102.89.45.101 at the identity provider / conditional access layer	Prevent further authentication attempts from known attacker infrastructure
3	Suspend the "RSS Subscriptions" inbox rule pending removal	Restore visibility of finance-related correspondence to the legitimate user

Table 5. Immediate containment actions and corresponding purpose.

12. Eradication Actions

- Remove the unauthorized "Pixel 6" authenticator device from Daniel Reeve's account.
- Delete the malicious "RSS Subscriptions" inbox rule from the affected mailbox.
- Reset passwords for both confirmed compromised accounts (daniel.reeve@cloudora.io and priya.nair@cloudora.io).
- Revoke all active refresh tokens and authentication sessions tenant-wide for the affected accounts.

- Review and remove any additional unauthorized application registrations, delegated mailbox permissions, or forwarding rules associated with the compromised accounts.

Note: As this investigation was conducted in a training environment, no live eradication actions were executed against production systems. The actions above represent the standard remediation procedure that would be applied in a live engagement.

13. Recovery Recommendations

- Reset passwords for all compromised accounts using strong, unique credentials in accordance with Cloudora's password policy.
- Remove unauthorized MFA devices and re-enroll legitimate users under supervised conditions.
- Delete malicious inbox rules and verify no additional persistence mechanisms remain (mail forwarding, delegated access, OAuth app consent grants).
- Revoke all active authentication sessions for the two confirmed compromised accounts.
- Review SharePoint Online activity logs associated with Priya Nair's account for evidence of document access, download, or exfiltration.
- Notify Cloudora finance stakeholders to manually verify any pending invoices or payment requests processed during the compromise window (2026-08-10 03:12 – 03:52 UTC).

14. Long-Term Security Improvements

- **Automated Password Spraying Detection:** Deploy behavioral analytics to flag low-and-slow authentication failure patterns across the user population, rather than relying solely on per-account lockout thresholds.
- **Impossible Travel Detection:** Enable conditional access policies that flag or block sign-ins with geographically implausible travel velocity.
- **Phishing-Resistant MFA:** Transition from SMS/authenticator app MFA to FIDO2 security keys or certificate-based authentication for privileged and finance-facing accounts.
- **Mailbox Rule Monitoring:** Implement automated alerting for inbox rule creation involving keywords such as "invoice," "finance," "payment," or rules that auto-mark messages as read or move them to low-visibility folders.
- **Authentication Method Change Alerting:** Alert on all new MFA device or security info registrations, particularly outside of expected onboarding workflows.
- **Security Awareness Training:** Conduct regular password hygiene and phishing awareness training for all employees, with emphasis on finance and executive personnel.

15. Lessons Learned

This investigation demonstrated the importance of correlating authentication logs with audit logs to reconstruct the complete attack lifecycle. Password spraying attacks generate relatively few authentication failures per account, making behavioral analysis more effective than monitoring individual failed login counts in isolation.

Persistence mechanisms such as unauthorized MFA registrations and malicious inbox rules can survive a password reset if not explicitly identified and removed during incident response. Regular monitoring of authentication anomalies, mailbox rule creation, and changes to authentication methods would significantly improve detection capability and reduce the impact of similar attacks in the future.

16. Conclusion

This investigation confirmed a successful, multi-stage account takeover of Cloudora's Microsoft 365 environment, originating from a password spraying campaign and progressing to persistence establishment and Business Email Compromise preparation. Two accounts were confirmed compromised, with clear evidence of attacker intent to conceal finance-related communications.

Based on the evidence gathered, this incident is assessed as **contained at the investigative stage**, with no confirmed evidence of completed financial fraud or data exfiltration. Prompt execution of the containment, eradication, and recovery actions outlined in this report is required to fully close out residual risk. Implementation of the long-term security improvements is strongly recommended to reduce the likelihood and impact of similar attacks against Cloudora's environment going forward.

17. Appendix

17.1 Important KQL Queries

The following Kusto Query Language (KQL) queries were used during this investigation and are provided for reuse in future threat hunting and detection engineering activities.

QUERY 1 — IDENTIFY PASSWORD SPRAYING PATTERN (FAILED AUTHENTICATION BY SOURCE IP)

```
CloudoraSignIn_CL
| where ResultType == "50126"
| summarize FailedAttempts = count(), TargetedAccounts = dcount(UserPrincipalName)
    by SourceIP = IPAddress, bin(TimeGenerated, 1d)
| where TargetedAccounts > 5
| order by FailedAttempts desc
```

QUERY 2 — SUCCESSFUL AUTHENTICATION FOLLOWING FAILED ATTEMPTS

```
CloudoraSignIn_CL
| where ResultType in ("50126", "0")
| summarize Results = make_set(ResultType), Times = make_list(TimeGenerated)
    by UserPrincipalName, IPAddress
| where Results has "50126" and Results has "0"
| order by UserPrincipalName asc
```

QUERY 3 — UNAUTHORIZED MFA / SECURITY INFO REGISTRATION

```
CloudoraAudit_CL
| where OperationName == "User registered security info"
| project TimeGenerated, UserPrincipalName, DeviceName, IPAddress
| order by TimeGenerated desc
```

QUERY 4 — MALICIOUS INBOX RULE CREATION

```
CloudoraAudit_CL
| where OperationName == "New-InboxRule"
| project TimeGenerated, UserPrincipalName, RuleName, RuleParameters
| order by TimeGenerated desc
```

17.2 IOC Summary

Type	Value	Recommended Action
IP Address	102.89.44.17	Block at identity provider / firewall
IP Address	102.89.44.23	Block at identity provider / firewall
IP Address	102.89.45.101	Block at identity provider / firewall
Device Name	Pixel 6	Remove from authenticator devices; alert on re-registration
Inbox Rule	RSS Subscriptions	Delete; alert on similarly named future rules
Email Address	finance@cloudora.io	Monitor for rule-based targeting
Keyword	invoice	Monitor mailbox rules referencing this keyword

Table 6. Consolidated indicator summary with recommended remediation action.

17.3 Investigation Notes

- All findings in this report are directly supported by *CloudoraSignIn_CL* and *CloudoraAudit_CL* log evidence; no evidence has been inferred or assumed beyond what was recorded in the source logs.
- This investigation was conducted within a simulated/training SOC environment. Actions listed under Sections 11–13 (Containment, Eradication, Recovery) reflect standard MSSP procedure and were not executed against live production systems.
- Analyst recommends a follow-up review 30 days post-remediation to confirm no recurrence of authentication anomalies from the identified attacker infrastructure.
- This report is classified **Confidential Internal and Client Distribution Only** and should not be shared outside of authorized Cloudora and Nimbus Shield MSSP personnel.

— End of Report —

18. Attached Source Log Files

The raw Microsoft 365 sign-in and unified audit logs referenced throughout this report (CloudoraSignIn_CL and CloudoraAudit_CL) are embedded in this PDF as file attachments and linked below for direct access.

CloudoraSignIn_CL

[Attachment] cloudora_signin_logs.csv

Microsoft 365 sign-in log telemetry used to reconstruct the password spraying campaign and confirm successful authentication events (Sections 4, 6, 9).

CloudoraAudit_CL

[Attachment] cloudora_audit_logs.csv

Unified audit log telemetry used to identify the unauthorized MFA registration and malicious inbox rule creation (Sections 4, 6, 7).

> **NOTE ON OPENING ATTACHMENTS**
>
> Use a desktop PDF reader (e.g. Adobe Acrobat/Reader) and open the Attachments panel to extract the embedded CSV files. Browser-based PDF viewers may not display attachments.